StudyFlow

Aplicação web |Autenticação | Proteção de dados | Auditoria | Direitos do titular

UMC UNIVERSIDADE

UMC SUMMIT 3ª EDIÇÃO PESQUISA, INOVAÇÃO E EXTENSÃO

PÓS UMC UNIVERSIDADE

1. INTRODUÇÃO

O projeto StudyFlow tem como objetivo centraliza atividades acadêmicas de um estudante em uma aplicação web. Nesta etapa, o foco foi estabelecer a base de segurança da aplicação: autenticação, recuperação de senha, comunicação protegida, auditoria e mecanismos de conformidade com a LGPD (ex: Registro do consentimento,Exclusão...).

2. METODOLOGIA

- Levantamento das funcionalidades e dos dados pessoais tratados.
- Definição da arquitetura entre cliente-servidor.
- Implementação dos mecanismos de autenticação, recuperação, segurança e LGPD.
- Testes funcionais com front-end, API, banco e fluxos de falha.
- Validação por evidências e ajustes obtidos em testes práticos.

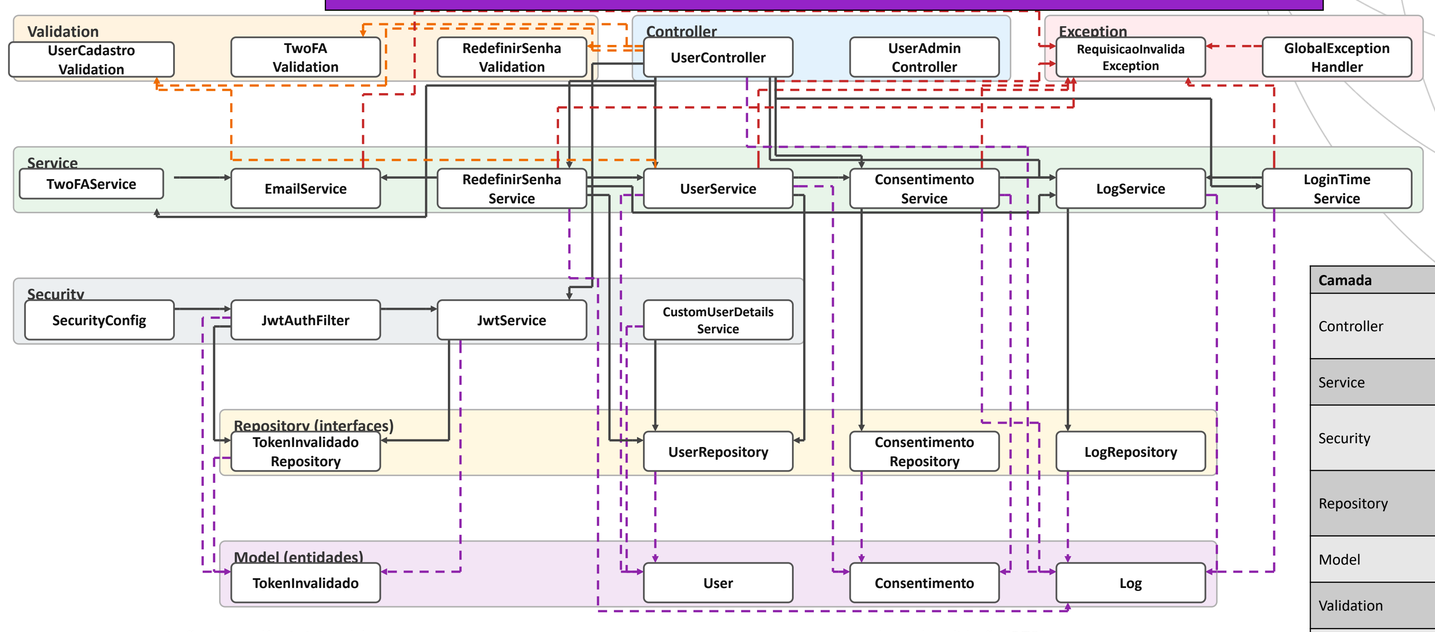
3. TECNOLOGIAS

Front-end
- React
- Vite
- JavaScript
- HTML5
- CSS3

Back-end
- SpringBoot
- Java
- PostgreSQL

Ferramentas / Serviços
- Git
- GitHub
- GitHub Projects
- Maven
- Docker
- Render
- Brevo
- Vercel
- NPM
- ESLint

4. ARQUITETURA



Camada	Função
Controller	Recebe as requisições da aplicação
Service	Contém as regras de negócio
Security	Autenticação, JWT e controle de acesso
Repository	Acesso e persistência dos dados
Model	Entidades do sistema
Validation	Validação dos dados recebidos
Exception	Tratamento de erros

5. RESULTADOS DOS CONTROLES IMPLEMENTADOS

BCrypt
- Senha armazenada com a criptografia BCypt onde conten hash + salt com 12 de custo.

2FA
- É gerado um código de 6 dígitos com validade de 5 minutos e é enviado ao email do usuario.

JWT
- Token válido por 30 min e invalidado no logout.

Proteção contra força bruta
- 5 tentativas incorretas e-mail bloqueado por 10 min.

HTTPS / TLS
- Comunicação entre front-end e back-end protegida HTTPS / TLS

Segredos protegidos
- Chaves JWT e API de e-mail em variáveis de ambiente.

6. FLUXO DE AUTENTICAÇÃO

1. **Cadastro** — Nome + e-mail + senha + consentimento
2. **Login** — E-mail + senha; verifica bloqueio e consentimento
3. **2FA** — Código de 6 dígitos validade 5 min
4. **Sessão** — JWT 30 min; filtro valida assinatura/expiração
6. **Logout** — Token entra na tabela de tokens_invalidados

7. RECUPERAÇÃO DE SENHA

1 • Solicitar
- É gerado token de 6 digitos e enviado para o email do usuario.

2 • Validar
- Token informado é verificado e expira em 5 minutos.

3 • Redefinir
- Senha + Confirmação, gerar uma nova senha com BCrypt

8. LGPD, CICLO DO TITULAR

Coleta
- Nome + e-mail (minimização)

Contimento
- Versão 1.0 finalidade + data

Exportar
- JSON com os dados do usuario

Consultar
- Consulta dos dados do usuario

Revogar
- Consentimento é marcado como revogado

Excluir
- Usuário e consentimentos removidos; logs anonimizados

Efeito da revogação

Após a revogação, o login é bloqueado até novo aceite. O reaceite cria um novo registro de consentimento e restabelece o acesso.

9. SEGURANÇA

- Força bruta: 5 tentativas → bloqueio por 10 min
- Roubo de sessão: JWT 30 min + blacklist no logout
- Interceptação: HTTPS/TLS + redirecionamento HTTP → HTTPS
- Vazamento de senha: BCrypt com salt automático
- Recuperação de senha: código de 6 dígitos, validade de 5 min e uso único
- Acesso não autenticado: JWT nas rotas protegidas

CAPES

FAEP FUNDAÇÃO DE AMPARO AO ENSINO E PESQUISA

CNPq CONSELHO NACIONAL DE DESENVOLVIMENTO CIENTÍFICO E TECNOLÓGICO

Higor de Castro Venancio da Silva
João Vitor Rodrigues
Engenharia de Software | UMC | 2026